

Security Assessment Report

Bloxhouse.id - Public / Sanitized Portfolio Version

Assessment Type	White Box Testing
Assessment Period	27-29 March 2026
Prepared By	Muhammad Khadafi
Publication Status	Sanitized for public portfolio use

Selected assessment materials are presented in sanitized form for portfolio purposes. Confidential information, customer data, credentials, and non-essential operational details have been excluded.

1. Executive Summary

A targeted white-box penetration test was conducted against the Bloxhouse platform, focusing on payment and invoice processing mechanisms. The assessment evaluated invoice generation, payment-related workflows, API behavior, parameter handling, and transaction integrity.

One medium-severity business logic weakness was identified in invoice generation. The affected functionality accepted a client-controlled pricing value without sufficiently validating it against the expected item price, allowing manipulated pricing data to be processed into generated invoice records.

The assessment did not achieve a direct payment bypass or unauthorized financial impact. The primary issue therefore represents a transaction-integrity weakness in invoice-generation logic rather than a demonstrated reduction of the amount charged through the main payment flow.

2. Scope & Authorization

Component	Status
Public Website	In Scope
Payment API	In Scope
Payment Bypass & Manipulation Testing	In Scope
Invoice Generation & Payment Logic	In Scope

3. Methodology

- Payment bypass scenarios
- Payment amount manipulation
- Invoice generation and pricing logic validation
- API parameter tampering within transaction-related requests
- Validation of transaction integrity and server-side controls

Testing was performed through controlled interaction with payment and invoice-related API endpoints and manual request manipulation. Activities were conducted in a controlled and non-destructive manner.

4. Findings Summary

ID	Finding	Severity	Status
F-01	Improper Price Validation in Invoice Generation API	Medium	Identified

5. Detailed Finding - F-01

Improper Price Validation in Invoice Generation API

Severity: Medium Status: Identified

Description

The invoice generation endpoint accepted a client-controlled pricing value without enforcing strict server-side validation. A manipulated transaction amount could be submitted through the request payload and processed by the backend without recalculating the value against the expected item price.

The original assessment demonstrated a mismatch between a client-supplied transaction value and the expected item price. The public version below generalizes the numerical test values while retaining the underlying parameter relationship.

Proof of Concept

```
{
  "totalPrice": <MANIPULATED_VALUE>,
  "items": [{"itemPrice": <EXPECTED_ITEM_PRICE>}]
}
```

Request

```
POST /api/invoice/generate-invoice
```

Observed result: the server returned a successful creation response and accepted the manipulated pricing value without server-side recalculation or validation against the expected item price.

Impact

- Manipulation of invoice pricing data
- Creation of inconsistent financial records
- Potential abuse of invoice-generation workflows
- Reduced reliability of transaction records and audit trails

Important limitation: No direct payment bypass or unauthorized financial loss was demonstrated during the assessment. The issue is therefore presented as a transaction-integrity and business-logic weakness.

Recommendation

- Enforce strict server-side validation of all transaction pricing values.
- Recalculate pricing on the backend from trusted product data.
- Reject requests containing inconsistent transaction values.
- Avoid relying on client-supplied financial values for authoritative records.

6. Security Controls Successfully Validated

Control Area	Result
Input validation and sanitization	PASS
Cross-Site Scripting (XSS) protection	PASS
SQL Injection (SQLi) protection	PASS
Payment amount validation controls	PASS
Payment bypass resistance	PASS

7. Exploitation Status

The original engagement was performed in a controlled manner. No active exploitation or unauthorized financial impact occurred during testing.

8. Conclusion

The assessment identified a weakness in invoice-generation logic where pricing values were not strictly validated on the server side. At the same time, the primary transaction flow successfully resisted direct payment bypass and payment amount manipulation attempts during the assessment.

The case demonstrates the importance of separating invoice integrity from payment integrity and of validating authoritative financial values on the server side.

9. Portfolio Disclosure

This document is a sanitized portfolio adaptation of an authorized penetration testing engagement. Selected technical details are retained to demonstrate assessment methodology and technical reasoning, while confidential or non-essential evidence has been generalized or removed.

References

OWASP Web Security Testing Guide (WSTG)

CWE-840: Business Logic Errors

CWE-20: Improper Input Validation

End of Report